

MONUMENTA

Políticas Internas

Política de Segurança da Informação e Tecnologia da Informação

POL-TI-01

Código: POL-TI-01

Área responsável: Tecnologia da Informação

Aprovação: Diretoria

Vigência: A partir da data de publicação

Política de Segurança da Informação e Tecnologia da Informação

1. Objetivo

Esta política estabelece as diretrizes, responsabilidades e regras de uso relacionadas à segurança da informação e aos recursos de tecnologia da informação (TI) da Monumenta, com o objetivo de proteger os ativos de informação da empresa e de seus clientes, garantir a continuidade das operações e assegurar a conformidade com a Lei Geral de Proteção de Dados (Lei nº 13.709/2018 — LGPD) e demais normas aplicáveis.

2. Abrangência

Esta política se aplica a todos os colaboradores da Monumenta, sejam eles empregados CLT, prestadores de serviço (PJ), estagiários, aprendizes ou terceiros que tenham acesso, ainda que temporário, aos sistemas, equipamentos, redes ou informações da empresa, independentemente do vínculo contratual ou do projeto/cliente ao qual estejam alocados (incluindo operações dedicadas como BB Promo, Petrobras, Sebrae, FUNCEF, APEX e Transpetro).

3. Princípios Gerais

A informação é um ativo estratégico da Monumenta e deve ser protegida contra acessos não autorizados, uso indevido, perda, vazamento ou destruição, respeitando os princípios de confidencialidade, integridade e disponibilidade.

4. Classificação da Informação

As informações da empresa devem ser tratadas de acordo com o seu grau de sensibilidade:

- **Pública:** informação que pode ser divulgada livremente, sem risco à empresa (materiais institucionais, campanhas já publicadas).
- **Interna:** informação de uso restrito aos colaboradores, sem risco relevante se exposta, mas que não deve ser divulgada externamente (comunicados internos, procedimentos operacionais).
- **Confidencial:** informação sensível cujo acesso é restrito a pessoas autorizadas (dados de clientes, contratos, propostas comerciais, dados financeiros, informações de projetos de clientes como Banco do Brasil, Petrobras, Sebrae, FUNCEF, APEX e Transpetro).
- **Restrita/Pessoal:** dados pessoais e dados pessoais sensíveis de colaboradores, clientes, fornecedores e participantes de eventos, sujeitos à LGPD (CPF, dados bancários, dados de saúde, biometria, entre outros).

5. Uso de Equipamentos e Recursos de TI

5.1. Os equipamentos (notebooks, desktops, celulares corporativos, tokens de acesso) fornecidos pela Monumenta são de uso profissional e devem ser utilizados prioritariamente para atividades relacionadas ao trabalho.

5.2. É vedado instalar softwares não homologados pela área de TI, desabilitar antivírus/firewall corporativo, ou realizar alterações não autorizadas nas configurações de segurança dos equipamentos.

5.3. Equipamentos e mídias removíveis (pen drives, HDs externos) devem ser protegidos contra perda e furto; qualquer extravio deve ser comunicado imediatamente à área de TI.

5.4. Ao término do contrato ou desligamento, todos os equipamentos, acessos e materiais fornecidos pela empresa devem ser devolvidos, e os acessos aos sistemas serão revogados no último dia de vigência do contrato.

6. Senhas e Controle de Acesso

6.1. O acesso a sistemas, e-mails e redes corporativas é individual e intransferível; é proibido compartilhar senhas, mesmo entre colegas de equipe.

6.2. As senhas devem seguir os critérios mínimos de complexidade definidos pela área de TI e devem ser trocadas periodicamente ou sempre que houver suspeita de comprometimento.

6.3. Sempre que disponível, deve ser utilizada autenticação em dois fatores (2FA), especialmente em sistemas que armazenam dados de clientes ou dados financeiros.

6.4. O acesso a sistemas e pastas deve seguir o princípio do menor privilégio: cada colaborador deve ter acesso apenas às informações necessárias para o exercício de sua função.

7. Uso de E-mail, Internet e Redes Sociais Corporativas

7.1. O e-mail corporativo deve ser utilizado para fins profissionais, sendo vedado seu uso para cadastro em serviços pessoais, correntes, spam ou conteúdo ofensivo.

7.2. Colaboradores devem adotar cautela redobrada com e-mails de remetentes desconhecidos, links suspeitos e anexos não solicitados (phishing), reportando imediatamente à TI qualquer suspeita.

7.3. O uso de redes sociais em nome da Monumenta ou de seus clientes deve seguir estritamente as diretrizes de comunicação e aprovação previamente definidas com cada cliente/projeto.

8. Proteção de Dados Pessoais (LGPD)

8.1. Todo colaborador que, no exercício de suas funções, tenha acesso a dados pessoais de clientes, fornecedores, colaboradores ou participantes de eventos (bases de convidados, formulários de credenciamento, listas de contato) deve tratá-los com confidencialidade e apenas para as finalidades previstas em contrato ou nas atividades do projeto.

8.2. É proibido copiar, extrair ou compartilhar bases de dados pessoais para uso fora do escopo autorizado, inclusive após o término do projeto ou do contrato de trabalho.

8.3. Qualquer incidente envolvendo vazamento, perda ou acesso indevido a dados pessoais deve ser comunicado imediatamente à área de TI/Compliance, para que os prazos legais de notificação previstos na LGPD sejam observados.

8.4. Dúvidas sobre o tratamento de dados pessoais em projetos específicos devem ser direcionadas à área responsável antes da execução da atividade.

9. Trabalho Remoto e Dispositivos Pessoais (BYOD)

9.1. Quando autorizado o acesso a sistemas corporativos por meio de dispositivos pessoais, o colaborador deve manter o dispositivo atualizado e protegido por senha, e comunicar imediatamente qualquer perda ou furto do aparelho.

9.2. Em ambientes públicos ou compartilhados, deve-se evitar o acesso a informações confidenciais em telas visíveis a terceiros e o uso de redes Wi-Fi públicas não seguras sem VPN.

10. Incidentes de Segurança

10.1. Considera-se incidente de segurança qualquer evento que comprometa a confidencialidade, integridade ou disponibilidade da informação (perda de equipamento, vazamento de dados, acesso indevido, infecção por vírus/ransomware, phishing bem-sucedido).

10.2. Todo colaborador tem o dever de reportar incidentes, suspeitas ou vulnerabilidades à área de TI imediatamente após a identificação, sem receio de retaliação por reportar de boa-fé.

11. Consequências do Descumprimento

O descumprimento desta política poderá acarretar, conforme a gravidade e reincidência, advertência verbal ou escrita, suspensão, rescisão do contrato de trabalho ou de prestação de serviços, sem prejuízo de eventuais medidas cíveis ou criminais cabíveis, especialmente em casos de vazamento de dados de clientes ou uso indevido de informações confidenciais.

12. Disposições Finais

Esta política deve ser revisada periodicamente pela área de TI, em conjunto com a Diretoria, para acompanhar mudanças legais, tecnológicas e operacionais. Casos omissos serão avaliados pela área de TI em conjunto com a Diretoria e/ou RH.